

04. 신뢰할 수 없는 Repository를 위한 Sandbox 설계

지원 가능한 저장소도 안전하다고 가정하지 않고, dependency lifecycle script와 build script까지 모두 신뢰하지 않는 실행으로 취급했습니다.

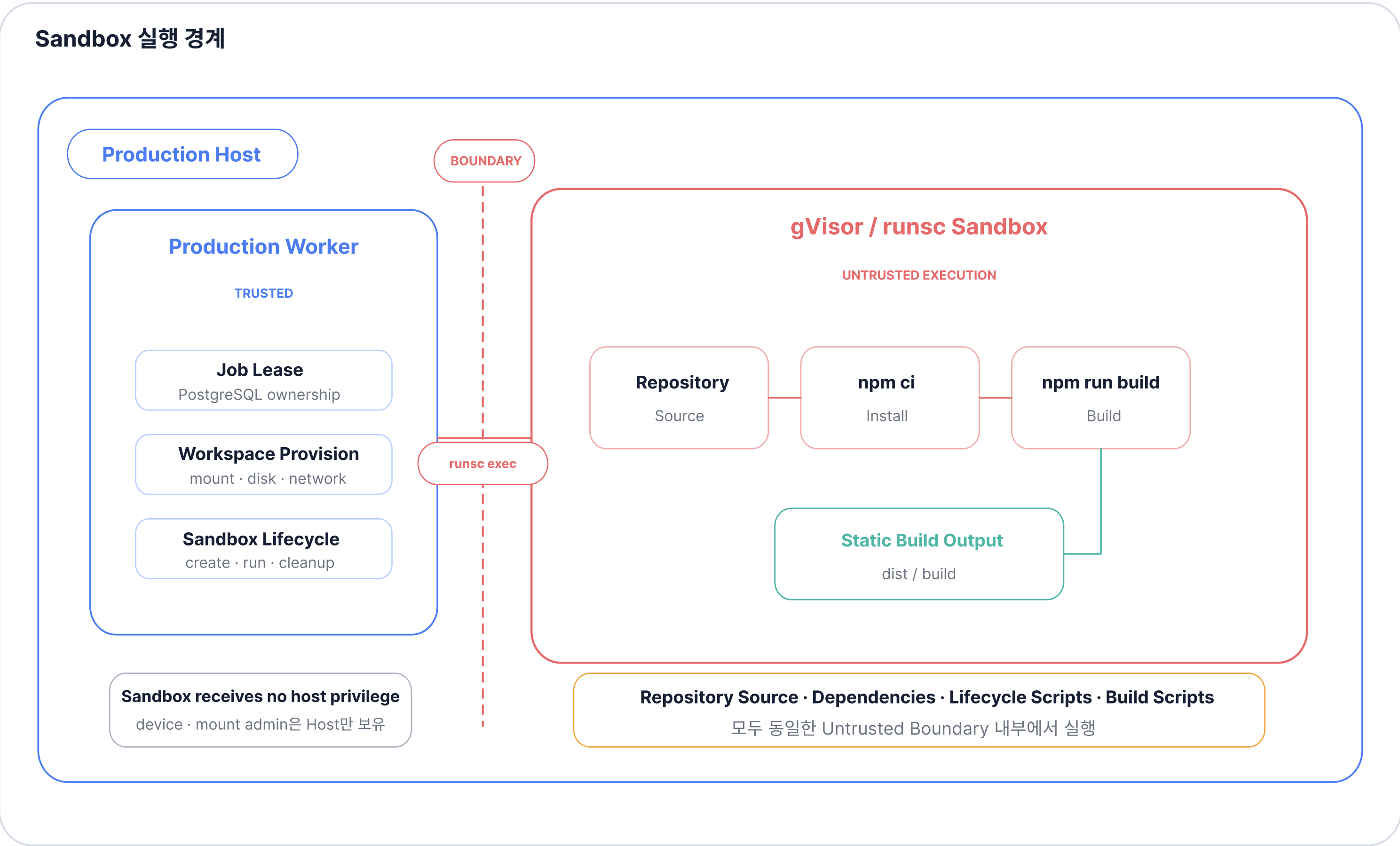
gVisor
real runsc sandbox

non-root
restricted execution

Disk Quota
loop-backed ext4

Network Policy
install / build 분리

Resource Limit
CPU · RAM · PID



실행 단계별 보안 제어

하나의 Sandbox만 두는 대신 실행·파일시스템·네트워크·리소스 경계를 각각 독립적으로 제한했습니다.

01. Execution

- real gVisor / runsc
- non-root user
- exact commit pinning
- host privilege 미전달

02. Filesystem

- guest root read-only
- loop-backed ext4 workspace
- hard capacity 적용
- job별 workspace 분리

03. Network

- Install 단계만 제한적 egress
- private / metadata 차단
- Build 단계 network disabled
- inter-job 접근 차단

04. Compute

- CPU bound
- Memory limit
- PID / process limit
- wall-clock timeout

SUPPORTED ≠ TRUSTED

Preview 가능 여부와 코드의 신뢰 여부를 분리하고, 실행이 필요한 경우에만 제한된 Sandbox에서 처리했습니다.